

Hypothèses d'intrusion — physique vs distant

AtlasGrid — Cellule de crise, Acte I

23/09/2026

Les deux captures collées dans le brouillon (USB / VPN) ressortent vides à l'extraction. Les captures ci-dessous viennent directement des pages du dossier KASBAH reçu.

Vecteur confirmé à ce jour — accès distant (VPN OasisNet)

Connexions répétées, hors heures ouvrées, sans MFA, depuis une IP hors du pays d'exploitation habituel. Le message du 15h02 le confirme : l'intrusion réelle « est passée par le VPN prestataire », la clé USB du parking n'étant qu'un leurre sans rapport.

```
=== FortiGate SSL-VPN · export du journal d'événements (39426) ===
Équipement : FGT-RBT-01   Généré : J1 13:10   filtre : user=svc_oasisnet

date   plage horaire   utilisateur   src_ip           mfa   octets_sortants
J-21   02:04-04:52      svc_oasisnet  196.200.114.41   non   1,2 Go
J-19   02:11-03:58      svc_oasisnet  196.200.114.41   non   0,8 Go
J-16   02:22-04:39      svc_oasisnet  102.118.53.17    non   1,4 Go
J-14   01:57-04:20      svc_oasisnet  102.118.53.17    non   1,6 Go
J-11   02:03-04:41      svc_oasisnet  102.118.53.17    non   1,7 Go
J-9    02:30-05:01      svc_oasisnet  102.118.53.17    non   2,1 Go
J-4    02:12-04:44      svc_oasisnet  102.118.53.17    non   1,9 Go
J-1    02:15-04:35      svc_oasisnet  102.118.53.17    non   1,8 Go

--- profil de référence (AD / RH) ---
svc_oasisnet : heures ouvrées 09:00-18:00, MFA=requis, src=plages OasisNet
géoIP(196.200.114.41 / 102.118.53.17) : hors du pays d'exploitation habituel

AtlasGrid · pièce d'exercice · ne pas copier-coller
```

A-02 — FortiGate SSL-VPN, journal d'événements (39426) **À noter** : colonne `mfa` à « non » sur les huit lignes, et `src_ip` hors des plages OasisNet habituelles — un compte de service qui se connecte sans MFA depuis l'étranger, la nuit, huit fois en trois semaines, ce n'est plus une anomalie isolée, c'est un pattern.

Ce que ça change : ces sorties de données commencent 21 jours avant le phishing, bien avant le week-end de l'email piégé. Deux fils probablement distincts : un abus prolongé du compte VPN d'OasisNet, et l'épisode plus récent (phishing puis ransomware sur FIN-112). Les hypothèses physiques ci-dessous restent secondaires tant que ce compte n'est pas expliqué.

Le même compte a aussi neutralisé les sauvegardes

SERVICE INFORMATIQUE preuve à qualifier **SOC / Détection**

Service informatique · SOC · détection

Le journal des travaux de sauvegarde. Il s'est passé quelque chose juste avant l'attaque, à vous de voir quoi.

 **Journal des travaux de sauvegarde**
A-05 · Veeam Backup & Replication · job history

```
--- Veeam Backup & Replication · historique des travaux ---
Serveur : VBR-01    Généré : J1 15:15

date  heure  travail                statut  opérateur
J-7   01:00   Daily-Backup-Job       Succès  système
J-6   01:00   Daily-Backup-Job       Succès  système
J-5   01:00   Daily-Backup-Job       Succès  système
J-4   01:00   Daily-Backup-Job       Succès  système
J-3   01:12   Politique de rétention MODIFIÉE (GFS)  svc_oasisnet
J-3   01:15   Daily-Backup-Job       Ignoré  (exclu par la nouvelle politique)
J-2   01:15   Daily-Backup-Job       Ignoré  (exclu par la nouvelle politique)
J-1   01:15   Daily-Backup-Job       Ignoré  (exclu par la nouvelle politique)
J1    03:15   Hôte FIN-112 : vssadmin delete shadows /all  [T1490]
J1    15:28   Dépôt BKP-01 : injoignable
J1    15:28   Dépôt BKP-02 : injoignable

AtlasGrid · pièce d'exercice · ne pas copier-coller
```

Votre verdict : **Preuve** Fausse piste Bruit

« Journal des travaux de sauvegarde » retenue comme preuve. Documentez-en la raison dès maintenant dans la main courante ; c'est ce que le jury examinera.

 **Le RSSI vous interroge :** Vos sauvegardes ont-elles tourné normalement, et jusqu'à quelle date pouvez-vous vraiment remonter ?

non, on a un problème à partir du J-3 après la modification de la politique les backup on été ignoré le jour J1 à 03:15 hôte FIN-112 lance une commande qui supprime tous les clichés instantanés en parallèle la protection des machines

Confiance : **Sûr** À confirmer

Transmettre au RSSI  **1 pièce à traiter (qualifier + justifier)**

16:22 ✓

A-05 — Veeam Backup & Replication, historique des travaux **À noter :** c'est `svc_oasisnet` — le même compte que dans A-02 — qui modifie la politique de rétention à J-3. Les trois sauvegardes suivantes sont ignorées à cause de ce changement, puis à J1 03h15, *la même minute que la désactivation de l'EDR sur FIN-112*, un `vssadmin delete shadows /all` supprime les clichés instantanés sur FIN-112 — T1490, suppression délibérée des moyens de restauration locale. Les deux dépôts de sauvegarde sont injoignables 12 heures plus tard.

Ce n'est plus un compte qui se connecte au mauvais moment : c'est le compte qui a désarmé la capacité de restauration avant que le ransomware ne s'exécute. La politique de rétention a été modifiée trois jours avant l'attaque — ce n'est pas improvisé.

Pour situer l'épisode récent — phishing puis FIN-112

```
=== Proofpoint · en-têtes bruts du message (RFC 5322) ===
Message-ID : <4f9c1e...@atlasgrid-it.info>   Mise en quarantaine : oui

Return-Path : <support-messagerie@atlasgrid-it.info>
Received : from mail.atlasgrid-it.info (193.42.55.108)
    by mx.atlasgrid.ma; [J1] 06:41:22 +0100
Authentication-Results : mx.atlasgrid.ma;
    spf=fail (IP émettrice 193.42.55.108 non autorisée) ;
    dkim=none (aucune signature) ;
    dmarc=fail (p=none) header.from=atlasgrid-it.info
From : "Support Messagerie" <support-messagerie@atlasgrid-it.info>
To : direction.financiere@atlasgrid.ma
Subject : Migration de votre messagerie · action requise avant ce soir
X-Mailer : PHPMailer 6.1
--- corps (extrait) ---
« Votre boîte sera suspendue ce soir. Revalidez vos identifiants : »
  hxxps://atlasgrid-it[.]info/owa/login   [T1566.002]

AtlasGrid · pièce d'exercice · ne pas copier-coller
```

A-11 — en-têtes du courriel de hameçonnage (Proofpoint) **À noter** : les trois vérifications échouent ensemble (spf=fail, dkim=none, dmarc=fail) et le domaine expéditeur `atlasgrid-it.info` imite le vrai `atlasgrid.ma` — ce n'est pas un cas limite à interpréter, les trois signatures disent la même chose.

```
=== Microsoft Defender for Endpoint · export d'alertes ===
Tenant : atlasgrid.onmicrosoft.com   Généré : J1 10:05 (UTC)
Requête : DeviceName in (FIN-112, RH-031) | order by Timestamp asc

Horodatage (UTC)  Poste  Menace  Sév.  Action
[J-42] 11:02:47  RH-031  PUA:Win32/Toolbar.Gen  Bas  Nettoyée
[J-42] 11:05:13  RH-031  PUA:Win32/Toolbar.Gen  Bas  Nettoyée
[J-35] 09:14:02  RH-031  PUA:Win32/Toolbar.Gen  Bas  Nettoyée
[J-1] 03:12:09  FIN-112  Ransom:Win32/Mirage.A  HAUT  QUARANTAINE ECHOUÉE
Fichier = C:\Windows\svchost32.exe
SHA256 = 3f9a4b1e9c2d7a5f0b8e6d41a97c...e0c71e
Signature = ABSENTE (binaire non signé)  Détection = ML.HighConfidence
[J-1] 03:13:55  FIN-112  Behavior:Win32/MassFileWrite  HAUT  Détectée
[J-1] 03:14:31  FIN-112  Blocage sortant -> 45.137.184.62:443 (contourné)
[J-1] 03:15:22  FIN-112  Altération : protection temps réel désactivée
    acteur=admin_local  technique [T1562.001]
--- fin de l'export (6 alertes) ---

AtlasGrid · pièce d'exercice · ne pas copier-coller
```

A-01 — journal EDR, poste FIN-112 (Microsoft Defender for Endpoint) **À noter** : lire les quatre dernières lignes comme une séquence, pas comme quatre alertes séparées : détection à 03h12, quarantaine échouée, chiffrement de masse à 03h13, puis à 03h15 la protection est désactivée *depuis un compte admin_local* — quelqu'un a repris la main sur la machine après l'échec de la quarantaine, ce n'est pas le malware qui a improvisé seul.

Corrélation temporelle — la clé de lecture

Tant que chaque preuve est lue isolément, on a quatre signaux séparés. Remises sur une même ligne de temps, la nuit J-1 raconte autre chose :

Heure	Source	Événement
J-3, 01h12	Veeam (A-05)	politique de rétention modifiée par svc_oasisnet
J-3 à J-1, 01h15	Veeam (A-05)	sauvegardes quotidiennes ignorées (nouvelle politique)
soirée J-1	boîte finance	email de hameçonnage reçu, identifiants saisis
02h00–04h00	badge (DRH)	badge du stagiaire IT, salle des serveurs
02h15–04h35	VPN (A-02)	session svc_oasisnet, sans MFA, 1,8 Go sortis
03h12	EDR (A-01)	exécution Ransom :Win32/Mirage.A sur FIN-112
03h13	EDR (A-01)	chiffrement en masse détecté (MassFileWrite)
03h14	EDR (A-01)	sortie C2 bloquée puis contournée
03h15	EDR (A-01)	défenses désactivées (admin_local, T1562.001)
03h15	Veeam (A-05)	vssadmin delete shadows /all sur FIN-112 (T1490)
15h28	Veeam (A-05)	dépôts BKP-01 et BKP-02 injoignables
17h20–17h24	DLP (A-17)	copie USB PAIE-SAUVE — <i>hors fenêtre nocturne</i>

Ce que la superposition des horaires montre : trois sources indépendantes — le badge, la session VPN et le journal EDR — convergent sur la *même* fenêtre de deux heures, la même nuit. Ce n'est pas une preuve de lien entre elles, mais ce n'est plus un hasard qu'on peut ignorer non plus. Et à 03h15 précisément, deux systèmes différents (EDR et Veeam) enregistrent chacun de leur côté un geste de sabotage sur FIN-112 — désactivation de la protection d'un côté, suppression des clichés de l'autre. La copie USB PAIE-SAUVE, elle, tombe 9 heures plus tôt en dehors de cette fenêtre — ce qui appuie encore le verdict « bruit » posé dessus.

La question que ça ouvre : le compte svc_oasisnet s'est connecté sur le même créneau nocturne (02h–05h) à huit reprises en 21 jours (J-21 à J-1), pas seulement cette nuit-là. Le journal badge ne couvre pour l'instant que la nuit J-1. Si les sept autres nuits montrent le même badge actif, la piste d'une présence physique récurrente prend du poids ; si c'est la seule fois, la convergence de cette nuit précise devient l'élément à expliquer en priorité, coïncidence ou non.

Hypothèses d'entrée physique

1. Clé USB abandonnée sur le parking visiteurs

Statut : écartée (FP-7)

Un employé l'a trouvée et l'a remise sans jamais la brancher. Analysée en bac à sable : contient un leurre (faux « bulletin de paie » exécutable), mais aucune trace de connexion à un poste AtlasGrid.

Journal détaillé (A-19) référencé mais pas encore transmis à la cellule — pas de capture disponible.

Pourquoi c'est une hypothèse et pas un fait : elle ressemble à un vecteur physique classique (USB drop), mais l'absence totale de log de connexion la réfute — ce n'est pas « peu probable », c'est vérifié négatif.

2. Clé USB « PAIE-SAUVE » branchée au service paie

Statut : qualifiée « bruit », à confirmer

```

=== DLP poste de travail · export des périphériques amovibles ===
hôte : PAIE-STA-3   Généré : J1 (sur demande)

_time      périphérique  action  fichier      taille
J-1 17:20  USB 'PAIE-SAUVE'  montage -          -
J-1 17:21  USB 'PAIE-SAUVE'  copie  bulletins_mois.zip  44 Mo (AES)
J-1 17:24  USB 'PAIE-SAUVE'  éjection -          -
--- contexte ---
utilisateur : gestionnaire de paie (session nominative + badge)
autorisation : ticket #4471 « sauvegarde manuelle avant clôture »
horaire      : heures ouvrées (17:20), hors de la fenêtre nocturne
volume       : 44 Mo (à comparer aux 117,8 Go de l'exfiltration nocturne A-03)
destination  : clé USB locale, aucune sortie réseau

AtlasGrid · pièce d'exercice · ne pas copier-coller

```

A-17 — DLP endpoint, journal des périphériques USB **À noter** : le bloc « contexte » fait tout le travail ici : ticket nommé, session nominative, horaire de bureau, 44 Mo en local sans sortie réseau — chacun de ces quatre champs, pris seul, pourrait aussi décrire une exfiltration maquillée ; c’est leur cohérence ensemble qui pèse pour « bruit », pas un seul champ.

Pourquoi c’est une hypothèse et pas un fait : copie autorisée, tracée par ticket et session nominative, à 17h20 — 9 heures avant la fenêtre 02h–04h où tout le reste se joue — et pour un volume dérisoire face aux 117,8 Go sortis la nuit par le VPN. Le RSSI demande quand même de ne pas l’écarter trop vite — un faux positif se justifie, il ne s’auto-déclare pas.

3. Badge du stagiaire IT utilisé la nuit, salle des serveurs

Statut : non confirmée

INTERNE / PARTENAIRE à recouper

Communication

La DRH · Ressources humaines

Anomalie de badge (à vérifier)

Bonjour,

Nous avons une remontée un peu troublante côté contrôle d'accès : le badge du stagiaire IT aurait été utilisé cette nuit de week-end, entre 02h et 04h, du côté de la salle des serveurs.

Je vous transmets l'information mais je vous demande la plus grande prudence : ne concluons rien avant d'avoir vérifié le journal complet de la badgeuse et l'état des équipements. Une accusation hâtive serait grave (voir A-14). La DRH.

Signalement DRH — anomalie de badge (journal complet A-14 non encore reçu) **À noter** : c’est un message, pas un journal — aucune donnée brute (heure exacte, identifiant de badge, porte franchie) n’est montrée ici, seulement un résumé. La DRH le dit elle-même : rien à conclure avant le journal complet de la badgeuse.

Pourquoi c’est une hypothèse et pas un fait : un badge « utilisé » ne dit pas qui l’a physiquement utilisé — vol, clonage ou prêt de badge restent possibles. Ce qui la rend intéressante n’est pas le badge seul, mais sa position dans la table ci-dessus : elle encadre à la fois la session VPN et les 03h12–03h15 de l’EDR, sans qu’on sache si c’est causal ou coïncident.

4. Coupure ou angle mort caméra ayant permis une entrée

Statut : aucune preuve reçue

Aucun journal de vidéosurveillance n'a été transmis à la cellule à ce stade. C'est une piste que vous soulevez, pas un élément du dossier.

Aucune pièce vidéosurveillance disponible — rien à montrer.

Pourquoi c'est une hypothèse et pas un fait : sans journal caméra (ou confirmation de panne), elle ne peut être ni confirmée ni exclue. C'est une demande à faire, pas une conclusion à tirer.